UNIVERSITÉ CHEIKH AHMADOUL KHADIM - UCAK

UFR MET - Département IT / Administration et Sécurité des Réseaux

MISE EN PLACE D'UNE SOLUTION DE GESTION DES VULNÉRABILITÉS (VMS)

Laboratoire EVE-NG reproduisant l'architecture du Data Center du Rectorat
(double liaison FO, cœur IOSv L3, 2 bâtiments, cloud IaaS — 15 nœuds + 2 clouds)

LIVRABLE 5

Objectif spécifique 6 : « Mettre en place un tableau de bord KPI »

Exploitation continue du VMS : scans planifiés (Fast quotidien / Full hebdomadaire)
· indicateurs (couverture, critiques par VLAN, MTTM, tendance, âge, automatisation)
· dashboard DefectDojo (MTTR calculé automatiquement)

Réalisé par	Makane SECK	Proposition / encadrement	Dr. Abdoul Aziz CISS (EPT)
Date de rendu	22 / 10 / 2026	Référentiel du lab	Documents 06 (Lab 5) · 04 §10-§11 — livrables 2 à 4

1. Objectif — la GdV comme processus continu

Les livrables 2 à 4 ont établi la chaîne détection → priorisation → remédiation sur un cycle ponctuel. L'objectif 6 prouve que cette chaîne devient un processus permanent et piloté par les indicateurs : les scans se déclenchent seuls (planifications), les résultats se consolident dans un tableau de bord (tableur) et dans le dashboard DefectDojo (MTTR et tendances calculés automatiquement), et chaque indicateur porte un seuil d'alerte qui déclenche une décision. Démarche : (1) planifier les scans récurrents dans GCE ; (2) exporter des rapports datés ; (3) relever les 7 indicateurs du guide ; (4) consolider dans DefectDojo ; (5) lire les tendances et décider.

2. Planification des scans récurrents (GCE)

Six planifications sont créées dans la GSA — Campus découpé par identifiant (un seul credential SMB/SSH par tâche dans la GSA), horaires décalés (contrainte mémoire), credentials à jour (règle du mémoire : toute désynchronisation des identifiants invalide le scan authentifié) :

GSA -> Scans -> « CAMPUS-W10 » (172.16.30.10, 172.16.31.11) -> cred SMB student — 06:00 quotidien
GSA -> Scans -> « CAMPUS-TC1 » (172.16.30.50) -> cred SMB admin — 06:45 quotidien
GSA -> Scans -> « CAMPUS-TC2 » (172.16.31.10) -> cred SMB olduser — 07:30 quotidien
GSA -> Scans -> « CAMPUS-CAM » (172.16.30.11) -> cred SSH admin — 08:15 quotidien
(la GSA n'accepte qu'UN credential SMB/SSH par tâche → Campus découpé PAR IDENTIFIANT, hôtes regroupés quand ils partagent le même compte ; horaires décalés = pics mémoire non cumulés — GBVA 4 GB ; le cred SNMP public s'ajoute à chaque tâche dans son champ)
GSA -> Scans -> « CLOUD-FULL » (10.9.1.10) -> Full and deep, cred scan — dimanche 02:00

Le scan authentifié reste la référence : le Full hebdo porte les credentials ; le Fast quotidien sert de détecteur de régression rapide (surface exposée).
Limite de production : une planification ne scanne que des actifs ALLUMÉS — un poste éteint à l'heure du scan n'est pas « reporté », il est ABSENT du rapport ; et dans la chaîne DefectDojo (« Close old findings »), ses constats antérieurs seraient clos automatiquement = mitigations fantômes et KPI mensongers. D'où : serveurs/cloud (24/7) de nuit, postes de travail en heures ouvrées (ou réveil Wake-on-LAN / API hyperviseur avant le scan), agent local pour les portables nomades ; le KPI couverture révèle toute fenêtre mal choisie.
Credentials : une MÊME tâche accepte PLUSIEURS identifiants — 3 SMB Windows (WIN-TC1, WIN-TC2, WIN-ADMIN ×2) + 1 SSH (Camera) + 1 SNMP (réseau) attachés à la tâche Campus ; GCE essaie chaque credential sur chaque hôte — sans correspondance, l'hôte reste « Authentifié : non » (visible dans le rapport, donc mesuré par le KPI couverture).

PREUVE 1
Liste des planifications actives dans la GSA (horodatée) + détail d'une planification (fréquence, cible, credentials attachées).

Schedule: UT C-W10

ID: 0cf7b06b-ab24-4d42-b19b-27f30abf03ae Created: Wed, Oct 21, 2026 6:20 PM Coordinated Universal Time
Modified: Wed, Oct 21, 2026 6:20 PM Coordinated Universal Time Owner: admin

Information | User Tags (0) | Permissions (0)

First Run	Wed, Oct 21, 2026 6:00 AM Coordinated Universal Time
Next Run	Thu, Oct 22, 2026 6:00 AM Coordinated Universal Time
Timezone	UTC
Recurrence	Every day
Duration	Entire Operation
Tasks using this Schedule	Campus-W10

Schedule: UT C-TC1

ID: 4ed85bf5-9b7a-4f59-9bdb-52ca9191f203 Created: Wed, Oct 21, 2026 6:36 PM Coordinated Universal Time
Modified: Wed, Oct 21, 2026 6:36 PM Coordinated Universal Time Owner: admin

Information | User Tags (0) | Permissions (0)

First Run	Wed, Oct 21, 2026 6:45 AM Coordinated Universal Time
Next Run	Thu, Oct 22, 2026 6:45 AM Coordinated Universal Time
Timezone	UTC
Recurrence	Every day
Duration	Entire Operation
Tasks using this Schedule	Campus-TC1

Schedule: UT C-TC2

ID: 6e44cd50-3c31-4e4b-ae35-ff13744db24e Created: Wed, Oct 21, 2026 9:10 PM Coordina
Modified: Wed, Oct 21, 2026 9:10 PM Coordinated Universal Time Owner: admin

Information | User Tags (0) | Permissions (0)

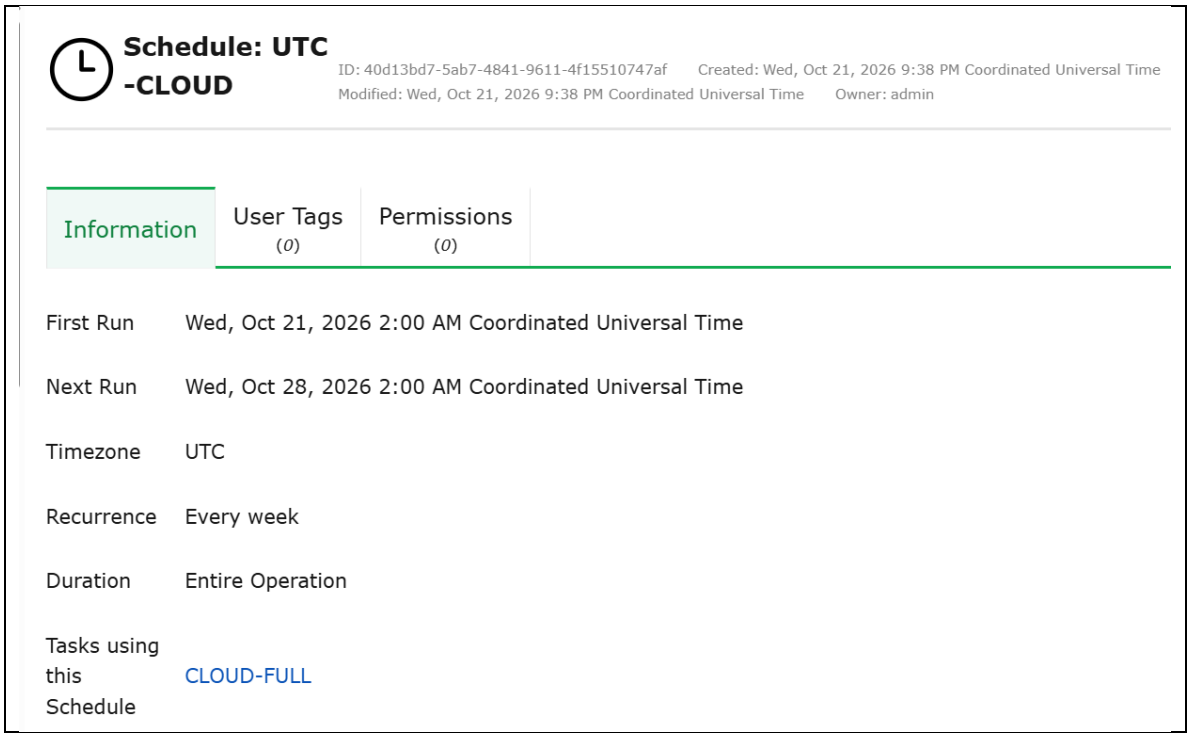
First Run	Wed, Oct 21, 2026 7:30 AM Coordinated Universal Time
Next Run	Thu, Oct 22, 2026 7:30 AM Coordinated Universal Time
Timezone	UTC
Recurrence	Every day
Duration	Entire Operation
Tasks using this Schedule	Campus-TC2

Schedule: UT C-CAM

ID: b1d2b6a0-a03b-4992-9b59-f820384ecc2d Created: Wed, Oct 21, 2026 9:17 PM Coordinated Universal Time
Modified: Wed, Oct 21, 2026 9:17 PM Coordinated Universal Time Owner: admin

Information | User Tags (0) | Permissions (0)

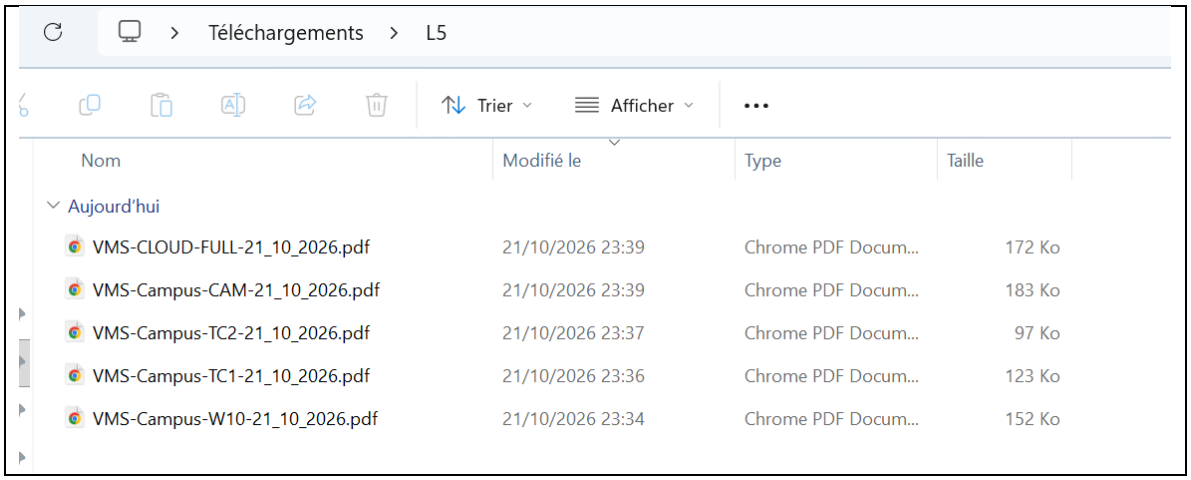
First Run	Wed, Oct 21, 2026 8:15 AM Coordinated Universal Time
Next Run	Thu, Oct 22, 2026 8:15 AM Coordinated Universal Time
Timezone	UTC
Recurrence	Every day
Duration	Entire Operation
Tasks using this Schedule	Campus-CAM



3. Exports de rapports datés

Chaque planification produit un rapport daté exporté en PDF et archivé (preuves/L5), nommé ***VMS-<tache>-<date>.pdf*** — cinq rapports : les 4 Fast quotidiens (campus, un par identifiant) et le Full authentifié (cloud, cred SSH scan). Convention d'alimentation de DefectDojo : seul le Full hebdomadaire est importé (engagement « Suivi hebdomadaire ») ; les Fast restent consultables dans la GSA — sinon la plateforme serait inondée et les clôtures/ouvertures automatiques deviendraient du bruit. C'est la matière première des indicateurs de la section 4 : un KPI sans source datée n'est pas un KPI

PREUVE 2
Les cinq rapports exportés (dates visibles sur la page de garde de chaque PDF) — au minimum le Full cloud et un Fast campus.



4. Le tableau de bord KPI (7 indicateurs)

Le tableau est tenu dans une feuille de calcul (une ligne de relevé par scan) ; les valeurs déjà acquises au lab sont reportées, les autres le seront à chaque cycle de scan.

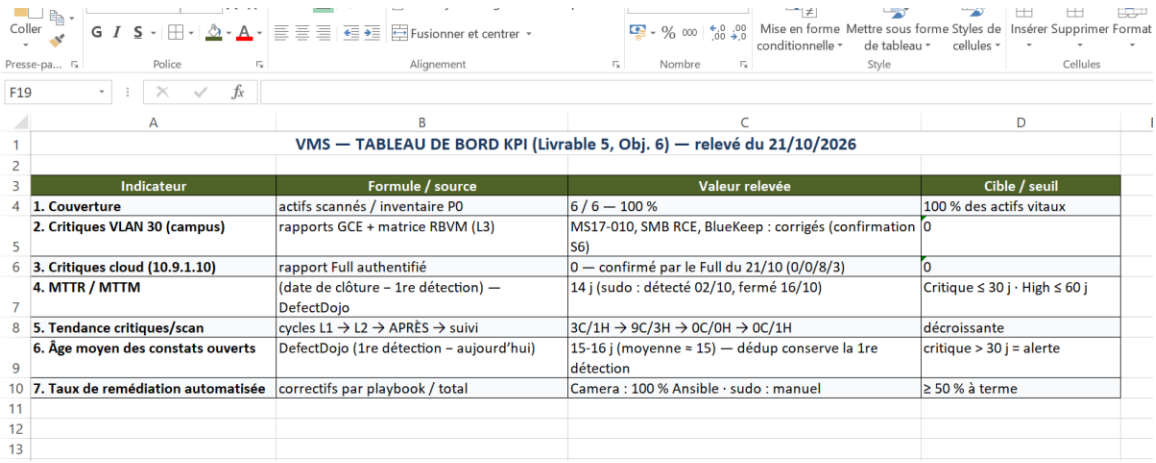
Indicateur	Formule / source	Valeur relevée (au 16-18/10)	Cible / seuil
1. Couverture	actifs scannés / actifs de l'inventaire P0	6 / 6 — 100 %	100 % des actifs vitaux
2. Critiques VLAN 30 (campus)	rapports GCE + matrice RBVM (L3)	MS17-010 · SMB RCE · BlueKeep — corrigés (re-scan de confirmation en S6)	0
3. Critiques cloud (10.9.1.10)	rapport Full authentifié	0 (sudo fermé le 16/10 — PREUVE 8 du L4)	0
4. MTTR / MTTM	Σ (date de clôture − 1re détection) / nb constats — calculé par DefectDojo	exemple mesuré : sudo 02/10 → 16/10 = 14 j (< SLA 30 j)	C ≤ 30 j · H ≤ 60 j
5. Tendance critiques/scan	L1 → L2 → ré-imports APRÈS	courbe ci-dessous — doit décroître	décroissante
6. Âge moyen des constats ouverts	DefectDojo (1re détection − aujourd'hui)	15-16 j (moyenne ≈ 15) — tous datent des scans L2 du 06-07/10 : la déduplication conserve la 1re détection	critique > 30 j = alerte
7. Taux de remédiation automatisée	correctifs par playbook / total des correctifs	Camera : 100 % Ansible (PREUVE 7 L4) · sudo : manuel	≥ 50 % à terme

4.2 Tendance — constats par cycle de scan

Cycle de scan	Date	Critiques	High	Commentaire
L1 — découverte réseau	05/10	3	1	baseline (non authentifié)
L2 — authentifié	13/10	9	3	révèle MS17-010, SMB RCE, BlueKeep, sudo
APRÈS remédiation (cloud)	16/10	0	1	8 M / 3 L — kernel volontairement gelés (scénario V-04)
Cycles planifiés (§2)	quotidien / hebdo	——	——	une ligne de relevé par scan

PREUVE 3

Feuille de calcul KPI remplie (7 indicateurs + historique des relevés par scan).



	A	B	C	D
1	VMS — TABLEAU DE BORD KPI (Livrable 5, Obj. 6) — relevé du 21/10/2026			
2				
3	**Indicateur**	**Formule / source**	**Valeur relevée**	**Cible / seuil**
4	**1. Couverture**	actifs scannés / inventaire P0	6 / 6 — 100 %	100 % des actifs vitaux
5	**2. Critiques VLAN 30 (campus)**	rapports GCE + matrice RBVM (L3)	MS17-010, SMB RCE, BlueKeep : corrigés (confirmation S6)	0
6	**3. Critiques cloud (10.9.1.10)**	rapport Full authentifié	0 — confirmé par le Full du 21/10 (0/0/8/3)	0
7	**4. MTTR / MTTM**	(date de clôture − 1re détection) — DefectDojo	14 j (sudo : détecté 02/10, fermé 16/10)	Critique ≤ 30 j · High ≤ 60 j
8	**5. Tendance critiques/scan**	cycles L1 → L2 → APRÈS → suivi	3C/1H → 9C/3H → 0C/0H → 0C/1H	décroissante
9	**6. Âge moyen des constats ouverts**	DefectDojo (1re détection − aujourd'hui)	15-16 j (moyenne ≈ 15) — dédup conserve la 1re détection	critique > 30 j = alerte
10	**7. Taux de remédiation automatisée**	correctifs par playbook / total	Camera : 100 % Ansible · sudo : manuel	≥ 50 % à terme
11				
12				
13				

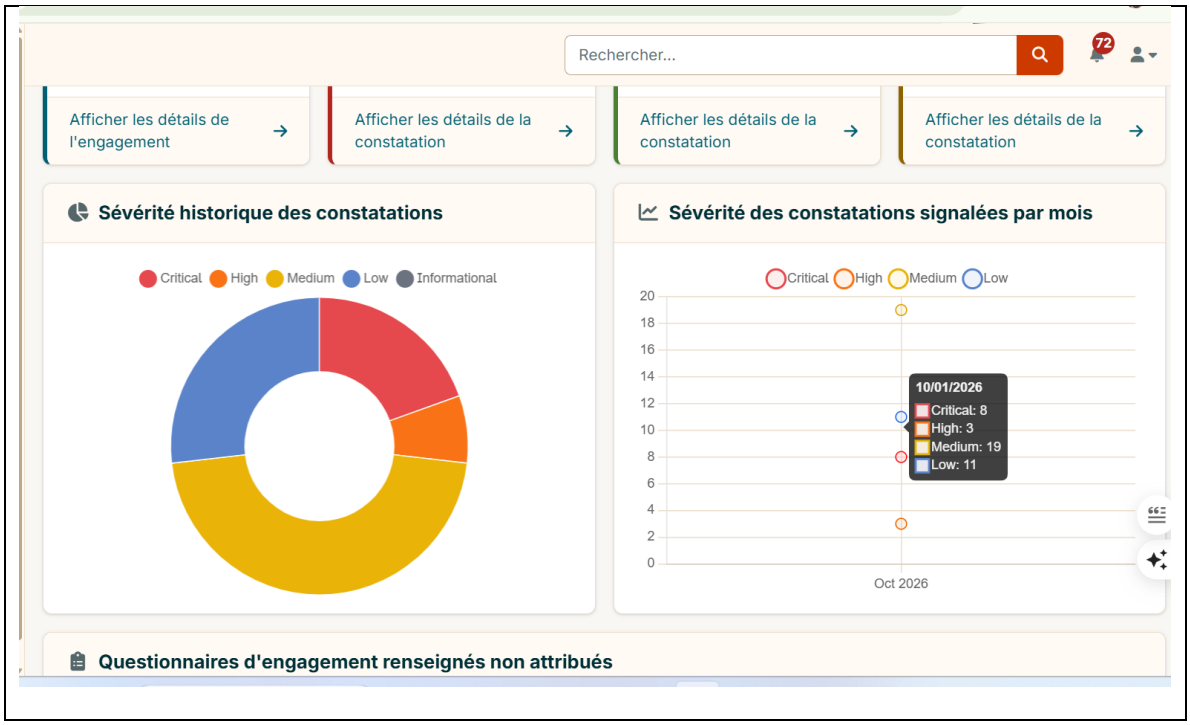
5. Consolidation — le dashboard DefectDojo

DefectDojo calcule automatiquement le MTTR (date de clôture − date de première détection, moyenné par sévérité) et les tendances de la pile de constats. La fermeture automatique du constat sudo (réimport « Clôturer les anciennes » du 16/10, livrable 4) alimente directement cet indicateur — aucune saisie manuelle. La page Metrics et les filtres par produit donnent la répartition par criticité et l'âge des constats ouverts ; le tableur (section 4) n'ajoute que les indicateurs hors plateforme : couverture, taux d'automatisation, lectures par VLAN.

```
DefectDojo -> Metrics : MTTR par sévérité · constats actifs · acceptés
Filtre produit = VMS (SRV-CLOUD, Win-7, Windows-10, Camera) — engagement « APRÈS remédiation »
```

PREUVE 4

Capture du dashboard DefectDojo horodatée : MTTR + répartition par criticité + âge des constats.



6. Lecture des indicateurs (ce qu'ils disent, ce qu'on décide)

Constat du tableau de bord	Décision associée
La boucle est mesurée de bout en bout : sudo détecté le 02/10, corrigé et clos automatiquement le 16/10 (14 j, sous le SLA critique)	le processus tient la promesse : aucun ticket critique ouvert sans preuve de correction
Les 8 Medium « kernel » du cloud restent ouverts volontairement (Ubuntu gelé, mitigations — V-04) : ils feront passer l'âge moyen au-delà de 30 j	risque assumé et formalisé (risk accepted dans DefectDojo, commentaire daté) pour le sortir du pilotage courant
La Camera est remédiée à 100 % par playbook (idempotence prouvée) ; SRV-CLOUD l'a été manuellement	le taux d'automatisation progresse à chaque cycle : tout correctif récurrent doit devenir un playbook (AWX = perspective)
Le Fast quotidien agit comme détecteur de régression à faible coût (surface exposée), le Full hebdo comme audit complet	si une régression apparaît : le constat ré-ouvert déclenche ticket + alerte Slack (matrice du L4)

7. Difficultés rencontrées

Difficulté rencontrée	Solution / contournement
Le MTTR de DefectDojo ne compte que les constats clôturés dans la plateforme (réimport « Clôturer les anciennes ») : une clôture faite seulement dans Jira n'alimente pas l'indicateur	discipline d'import : toute correction passe par un re-scan + réimport AVANT/APRÈS dans le même engagement
L'indicateur « âge moyen » est tiré vers le haut par des constats volontairement non corrigés (kernel gelés, V-04)	les sortir du pilotage par un risque assumé formalisé, sinon le KPI ne veut plus rien dire

8. Conclusion

Le tableau de bord transforme la pile de constats en signal de pilotage : la couverture garantit qu'on regarde le bon périmètre, la tendance et le MTTR prouvent que la remédiation progresse, l'âge et le taux d'automatisation disent où il faut investir (playbooks, risques assumés). La semaine 6 ferme la boucle du mémoire : livrable 6 + Atelier C — campagne de non-régression qui rejoue les scans sur toutes les remédiations (réseau, Windows, cloud, Camera, IOS) pour prouver qu'elles tiennent, puis rapport final.